LinuxVaultAudit

Audit et durcissement des permissions d'un serveur de fichiers Linux

1. Synthèse exécutive

Un audit des permissions du serveur de fichiers de NovaTech SARL a mis en évidence cinq anomalies critiques ou moyennes sur les dossiers RH, comptabilité, direction et IT, dont un fichier de données salariales modifiable par tout utilisateur du système et une clé privée SSH lisible publiquement.

L'ensemble des anomalies identifiées a été corrigé par application du principe du moindre privilège, puis vérifié par un second audit. Un contrôle d'accès fin (ACL) a été mis en place là où les permissions UNIX standard ne pouvaient pas répondre au besoin métier.

Ce rapport présente le périmètre, la méthodologie, les constats, les actions correctives appliquées et les recommandations pour maintenir ce niveau de sécurité dans la durée.

2. Périmètre de l'audit

L'audit a porté sur l'arborescence /srv/novatech, qui héberge les données des services suivants :

- RH — fichier de données salariales
- Comptabilité — dossier partagé de travail
- Direction — clé d'authentification SSH et notes confidentielles
- IT — script de sauvegarde de la base de données

3. Méthodologie

L'audit s'est déroulé en cinq étapes : relevé de l'état initial des permissions (ls -l, stat), détection automatisée des anomalies par recherche ciblée (find -perm), définition d'une politique d'accès par rôle métier, application des corrections via un script automatisé testé préalablement en mode simulation, puis vérification finale par un second audit identique au premier.

4. Constats de l'audit initial

Cinq anomalies ont été identifiées, classées selon leur niveau de risque :

Ressource	Propriétaire	Groupe	Droits constatés	Niveau de risque
/srv/novatech/rh/salaires.csv	root	novatech_rh	666 (-rw-rw-rw-)	Critique
/srv/novatech/it/backup_db.sh	root	root	777 (-rwxrwxrwx)	Critique
/srv/novatech/direction/id_rsa	root	novatech_direction	644 (-rw-r--r--)	Critique
/srv/novatech/compta	root	novatech_compta	777 (drwxrwxrwx)	Critique
/srv/novatech/direction/notes.txt	root	novatech_direction	644 (-rw-r--r--)	Moyen

Détail des risques :

- salaires.csv : données salariales lisibles et modifiables par tout utilisateur du système.
- backup_db.sh : script exécutable et modifiable par tous, exécuté avec les droits du compte root.
- id_rsa : clé privée SSH lisible par tout le monde — risque de compromission d'identité.

- compta/ : dossier dans lequel n'importe quel utilisateur peut créer ou supprimer des fichiers.
- notes.txt : notes confidentielles de la direction lisibles par l'ensemble des utilisateurs.

5. Politique d'accès recommandée

La politique suivante, fondée sur le principe du moindre privilège, a été définie puis appliquée :

Ressource	Groupe cible	Droits cibles	Justification
salaires.csv	novatech_rh	640 (-rw-r-----)	Lecture/écriture réservées au service RH
backup_db.sh	novatech_it	750 (-rwxr-x---)	Exécutable par le groupe IT uniquement
id_rsa	novatech_direction	600 (-rw-------)	Clé privée : accès propriétaire seul
compta/	novatech_compta	750 (drwxr-x---)	Écriture réservée au groupe comptabilité
notes.txt	novatech_direction	640 (-rw-r-----)	Lecture/écriture réservées à la direction

6. Actions de remédiation appliquées

Les corrections ont été appliquées à l'aide d'un script automatisé, testé préalablement en mode simulation (dry-run) pour valider chaque changement avant son exécution réelle — une pratique recommandée pour limiter le risque d'erreur en environnement de production.

7. Gestion des accès partagés (ACL)

Le dossier compta/ devait rester accessible en lecture/écriture pour le service comptabilité, tout en étant consultable en lecture seule par la direction — un besoin que les permissions UNIX classiques ne peuvent pas satisfaire, celles-ci n'autorisant qu'un seul groupe par ressource.

Une liste de contrôle d'accès (ACL) a été ajoutée pour accorder au groupe direction un accès en lecture seule, sans modifier les droits du groupe comptabilité propriétaire du dossier.

8. Vérification et résultats

Un second audit, identique au premier, a confirmé l'absence de toute anomalie résiduelle. Le tableau ci-dessous récapitule l'évolution des permissions :

Ressource	Avant	Après
salaires.csv	666	640
backup_db.sh	777	750
id_rsa	644	600
compta/	777	750 + ACL (lecture direction)
notes.txt	644	640

9. Recommandations

- Reconduire cet audit de permissions à intervalle régulier (trimestriel recommandé) pour prévenir toute dérive.

- Étendre la même démarche aux fichiers de configuration système sensibles (/etc/passwd, /etc/shadow, /etc/sudoers).
- Intégrer le contrôle automatisé des permissions dans le pipeline d'intégration continue.
- Documenter et faire approuver formellement la politique d'accès par les responsables de chaque service.

10. Annexe — Preuves d'audit

Les captures ci-dessous documentent chaque étape de l'audit, de l'état initial à la vérification finale.

10.1 État initial des permissions

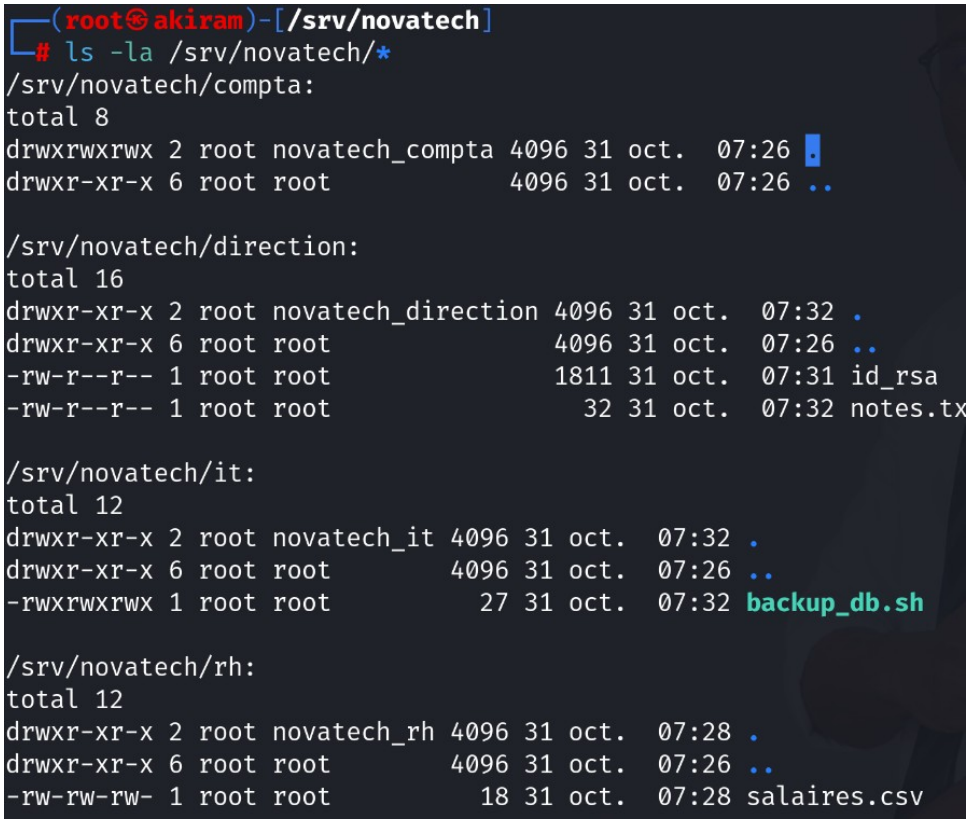


Figure 1 — Relevé des permissions avant correction (ls -la)

10.2 Détection des anomalies

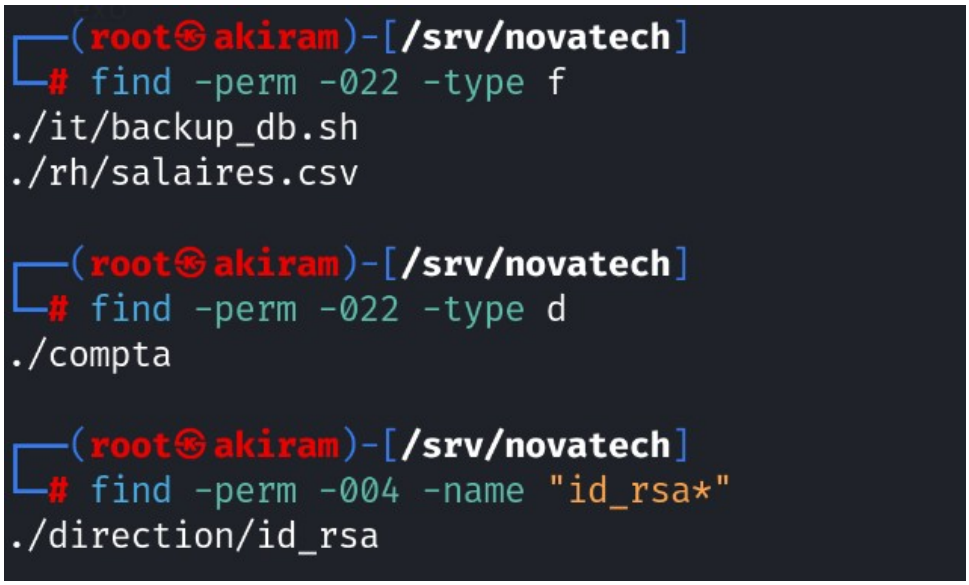


Figure 2 — Anomalies détectées par recherche ciblée (find -perm)

10.3 Simulation de la correction

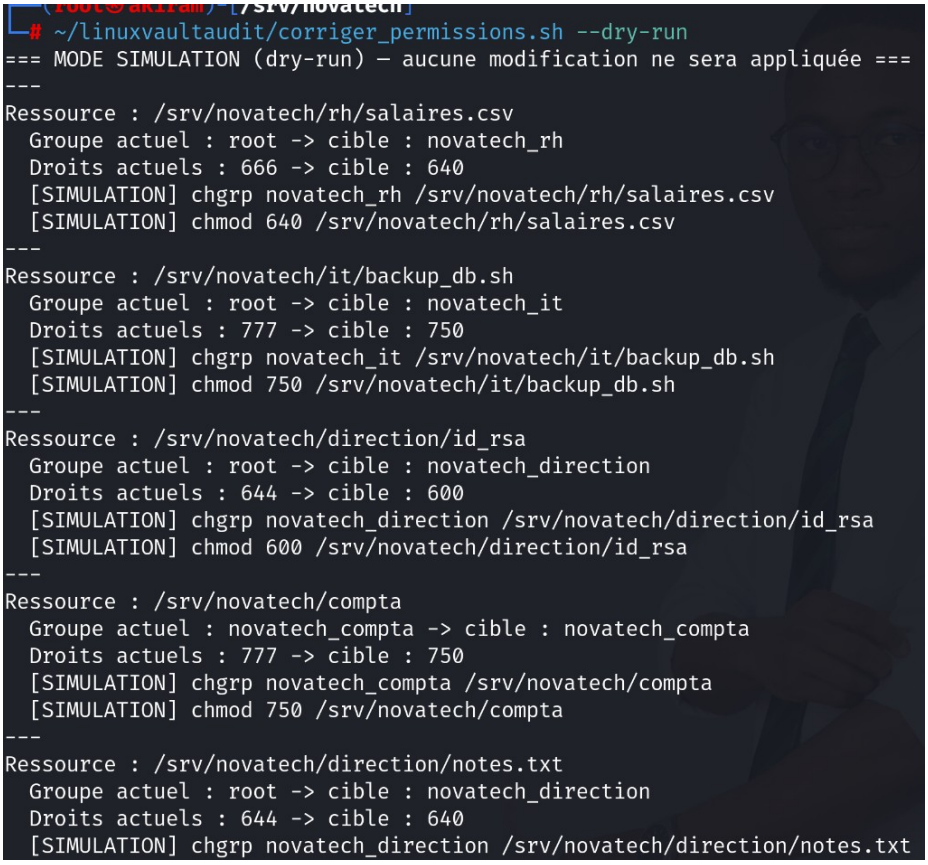


Figure 3 — Exécution du script de correction en mode simulation (--dry-run)

10.4 État après correction

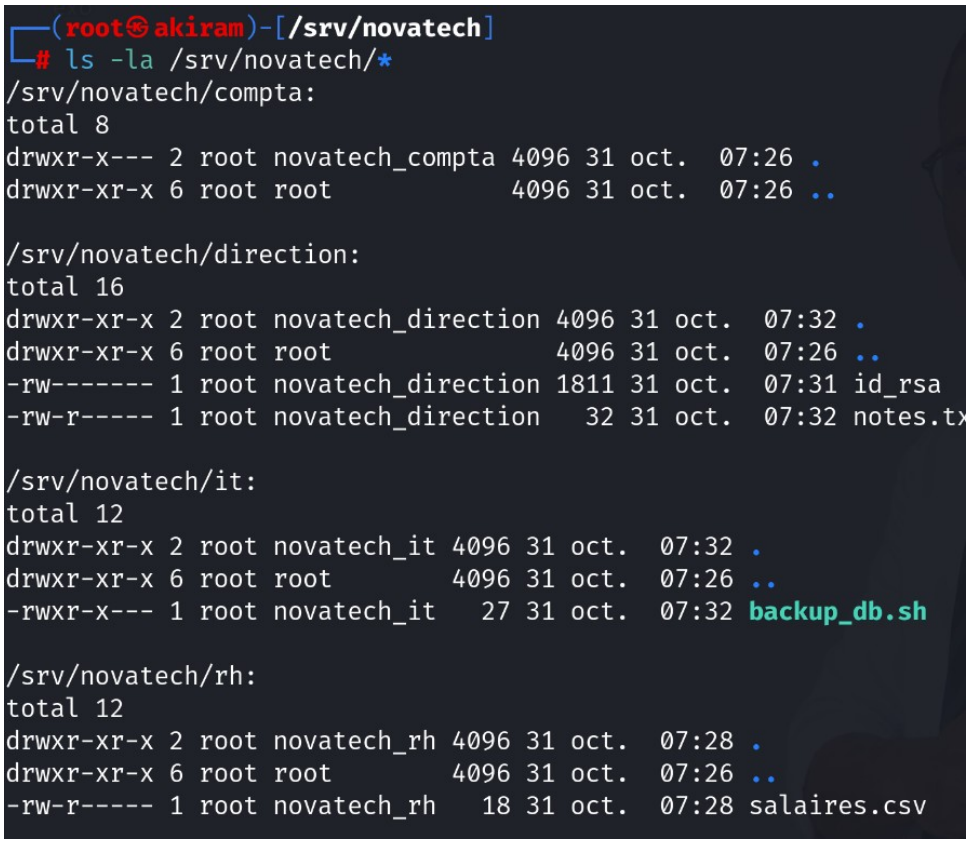


Figure 4 — Relevé des permissions après correction (ls -la)

10.5 Vérification automatisée

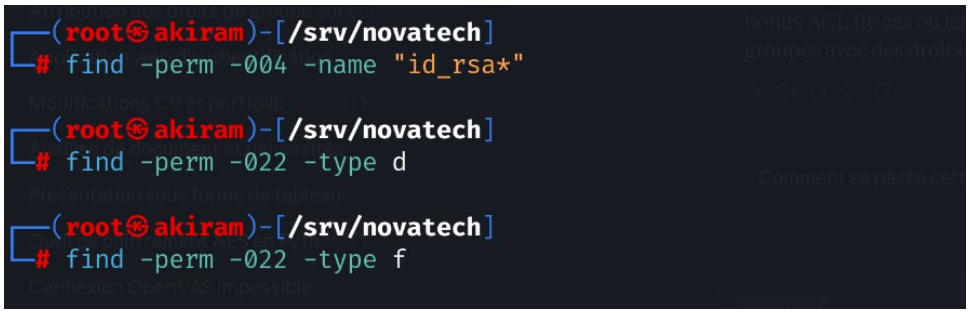


Figure 5 — Recherche ciblée après correction : aucune anomalie résiduelle

10.6 Gestion fine des accès (ACL)



Figure 6 — Dossier compta avant ajout de l'ACL

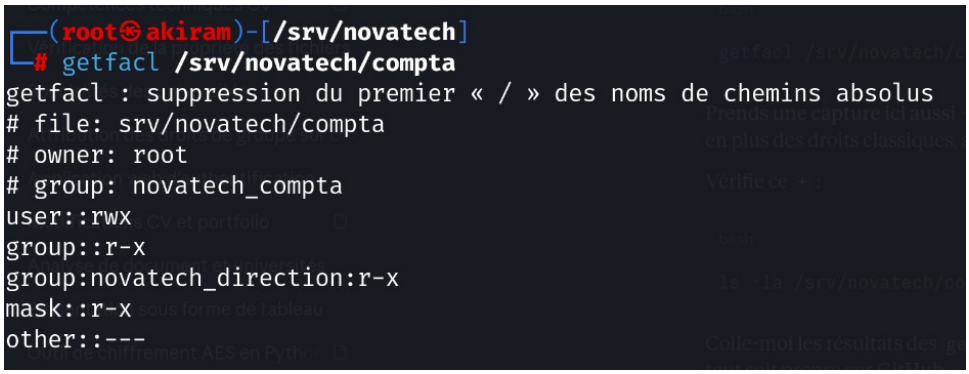


Figure 7 — ACL ajoutée : accès en lecture seule pour le groupe direction

11. Conclusion

L'audit a permis d'identifier et de corriger cinq failles de permissions présentant un risque réel pour la confidentialité et l'intégrité des données de NovaTech SARL. La mise en œuvre d'une politique d'accès formalisée, associée à un contrôle régulier, permettra de maintenir ce niveau de sécurité dans la durée.